Week 2- Gap analysis: M02 File Server (fileserver01)

Why: The audit lists what is wrong on the machine. The gap analysis explains, for each finding, what good practice expects (CIS Controls v8), what is missing, and how urgent it is. This is the basis of the risk register in Week 3.

1-Audit facts

Item	Value
Machine	M02- File Server fileserver01(Ubuntu 24.04.5 LTS), criticality High in the asset inventory
Data held	Payroll (Restricted), client records (Confidential), internal docs (Internal), website content & brochures (Public)
Tool and date	Lynis 3.0.9, command sudo lynis audit system, 6 November, 2026
Hardening index	57 out of 100 (higher = better hardened
Tests performed	252
Findings	2 warnings & 38 suggestions
Evidence	W2_Screenshots, Figures 1 to 4. Raw files kept on the machine, protected by the snapshot "Lynis audit done".

2-Method

Key terms

• **Warning**: an important problem to fix.

• **Suggestion**: a recommended improvement.

• **Lynis ID (e.g AUTH-9230)**: the test reference, explained on cisofy.com/lynis/controls/.

Steps

• **1- Group**: findings on the same subject are put together. Example: the 7 password findings become one theme (G3). 40 findings → 12 themes.

• **2- Match**: each theme is linked to one of the CIS Control v8. If none fits exactly, the closest is used and marked "closest control".

• **3- Compare**: what CIS expects, what the audit found, and the gap.

• **4- prioritize**: using the rule below.

Priority rule

• **High:** a basic protection is missing and payroll or client data is directly exposed.

• **Medium**: an extra layer of protection or detection is missing.

• **Low**: good practice, limited impact.

3-Summary

#	Theme	CIS Control v8	Lynis evidence	Priority
G1	Missing updates	7- Continuous Vulnerability Management	Warning PKGS-7392; PKGS-7392, PKGS-7394, DEB-0810, DEB-0811, LYNIS	High
G2	Firewall without rules	4- Secure config of Enterprise Assets & Software	Warning Fire-4512	High
G3	Passwords & logins	5- Account Management	AUTH-9229, AUTH-9230, AUTH-9262, AUTH-9282, AUTH-9286 (×2), DEB-0880	High
G4	No malware scanner	10- Malware Defenses	HRDN- 7230	High
G5	Logging	8- Audit Log Management	LOGG-2154, ACCT-9622, ACCT-9626, ACCT-9628	Medium
G6	File integrity	3- Data Protection (closest control)	FINT-4350, PKGS-7370	Medium
G7	Boot & system settings	4- Secure config of Enterprise Assets & Software	BOOT-5122, BOOT-5264, KRNL-5820, KRNL-6000, DEB-0280	Medium
G8	Unused protocols & USB	4- Secure config of Enterprise Assets & Software	NETW-3200 (×4), USB-1000	Medium
G9	File permissions	3- Data Protection	FILE-7524, AUTH-9328	Medium
G10	Disk partitions	4- Secure config of Enterprise Assets & Software	FILE-6310 (×3)	Low
G11	Login banners	4- Secure config of Enterprise Assets & Software (closest control)	BANN-7126, BANN-7130	Low
G12	Management tools & DNS	4- Secure config of Enterprise Assets & Software (closest control)	TOOL-5002, NAME-4028	Low

Check: G1 to G12 cover the two warnings and all 38 suggestions.

4-Detail by theme

G1- Missing updates (High)

• **CIS expects**: Track vulnerabilities and apply security updates.

• **Found**: Vulnerable packages installed (warning PKGS-7392); 27 updates waiting at login (W1_Screenshots); no update-helper tools (PKGS-7394, DEB-0810, DEB-0811); Lynis itself over 4 months old (LYNIS).

• **Gap:** Known security flaws stay open the server holding payroll and client data.

G2- Firewall without riles (High)

• **CIS expects:** A configured firewall on servers.

• **Found**: Firewall installed (Firewall [V]) but no active rules (warning FIRE-4512).

• **Gap**: Nothing is filtered: any service running on the server can be reached from the network.

G3- Passwords and logins (High)

• **CIS expects**: Managed accounts and strong passwords.

• **Found**: No password strength check (AUTH-9262), no password age limits (AUTH-9286), no expiry dates (AUTH-9282), hashing not configured (AUTH-9229, AUTH-9230), no blocking of repeated failed logins (DEB-0880).

• **Gap**: Weak or old passwords are accepted, and password guessing is not stopped.

G4- No malware scanner (High)

• **CIS expects**: Protection against malicious software.

• **Found**: No malware scanner (HRDN-7230; Malware scanner [X]).

• **Gap**: Infected files could be stored on the server and opened by staff.

G5- Logging (Medium)

• **CIS expects**: Collect, review and keep audit logs.

• **Found:** Logs not sent to a separate system (LOGG-2154); process accounting, sysstat and auditd off (ACCT-9622, ACCT-9626, ACCT-9628).

• Gap: After an incident, it would be hard to know what happened.

G6- File integrity (Medium)

• **CIS expects:** Closest control: protect sensitive data, including detecting changes to it.

• **Found**: No file integrity tool (FINT-4350); no package check tool (PKGS-7370).

• **Gap**: Changes to important files would go unnoticed.

G7- Boot and system settings (Medium)

• **CIS expects:** Systems follow a secure configuration.

• **Found**: No boot menu password (BOOT-5122); services not hardened (BOOT-5264); core dumps not restricted (KRNL-5820); Kernel settings differ from the hardened profile (KRNL-6000); libpam-tmpdir missing (DEB-0280).

• **Gap**: The server mostly runs on default settings.

G8- Unused protocols and USB (Medium)

• **CIS expects:** Remove or disable what is not needed.

• **Found**: Four unneeded network protocols available (NETW-3200: dccp, sctp, rds, tipc); USB storage enabled (USB-1000).

• **Gap**: Extra ways in, and data can be copied out on USB.

G9- File permissions (Medium)

• **CIS expects:** Data access limited to those who need it.

• **Found**: Some permissions could be stricter (FILE-7524); default permission for new files (unmask) not set to 027 (AUTH-9328).

• **Gap**: New files may be readable by more users than needed.

G10- Disk partitions (Low)

• **CIS expects:** Secure configuration, including disk layout.

• **Found**: /home, /tmp and /var not on separate partitions (FILE-6310).

• **Gap:** One full area can affect the whole server. Hard to change after installation.

G11- Login banners (Low)

• **CIS expects:** Closest control: a legal warning at login is part of a secure configuration.

• **Found**: No login banner (BANN-7126, BANN-7130).

• **Gap:** Unauthorized users are not warned.

G12- Management tools and DNS (Low)

• **CIS expects:** Closest control: a process to keep configurations consistent.

• **Found:** No configuration management tool (TOOL-5002); DNS domain name not set (NAME-4028).

• **Gap:** Settings are managed by hand.

5- Already in place

• **Firewall installed**: only the rules are missing (G2).

• **Only 2 warnings in 252 tests**: most findings are improvements, not urgent problems.

6- Main result

Four high gaps on the file server; missing updates (G1), firewall without rules (G2), weak password rules (G3) and no malware scanner (G4). They become risks in the Week 3 register risk.

7- Sources

Audit evidence (primary)

• Lynis 3.0.9 audit of M02, 6 November 2026: W2_Screnshots, Figures 1 to 4.

• Asset inventory and W1_Screenshots (criticality of M02, 27 pending updates).

Lynis

• Lynis test descriptions: cisofy.com/lynis/controls/followed by the test ID (the address Lynis itself prints in its output, for example cisofy.com/lynis/controls/AUTH-9230/)

• Hardening index, a score from 0 to 100: Linode, *Security Auditing with Lynis*, linode.com/docs/guides/security-auditing-with-lynis.

CIS Controls v8

• The 18 CIS Controls: cisecurity.org/controls/cis-controls-list

• CIS Controls v8 release (May 2021, 18 controls): cisecurity.org/insights/blog/ongoing-evolution-cis-critical-security-controls.

Method note

• No official Lynis-to-CIS mapping was used. Matching each theme to a CIS Controls is my own analysis, basis on the purpose of each control. Where no control fits exactly, it is marked “closest control”.

Sources

• The 18 CIS Critical Security Controls – CIS

• The Ongoing Evolution of the CIS Critical Security Controls – CIS

• Security Auditing with Lynis – Linode